

SOCIAL MEDIA EXTENSIONS

ARCH REQ6

09/28

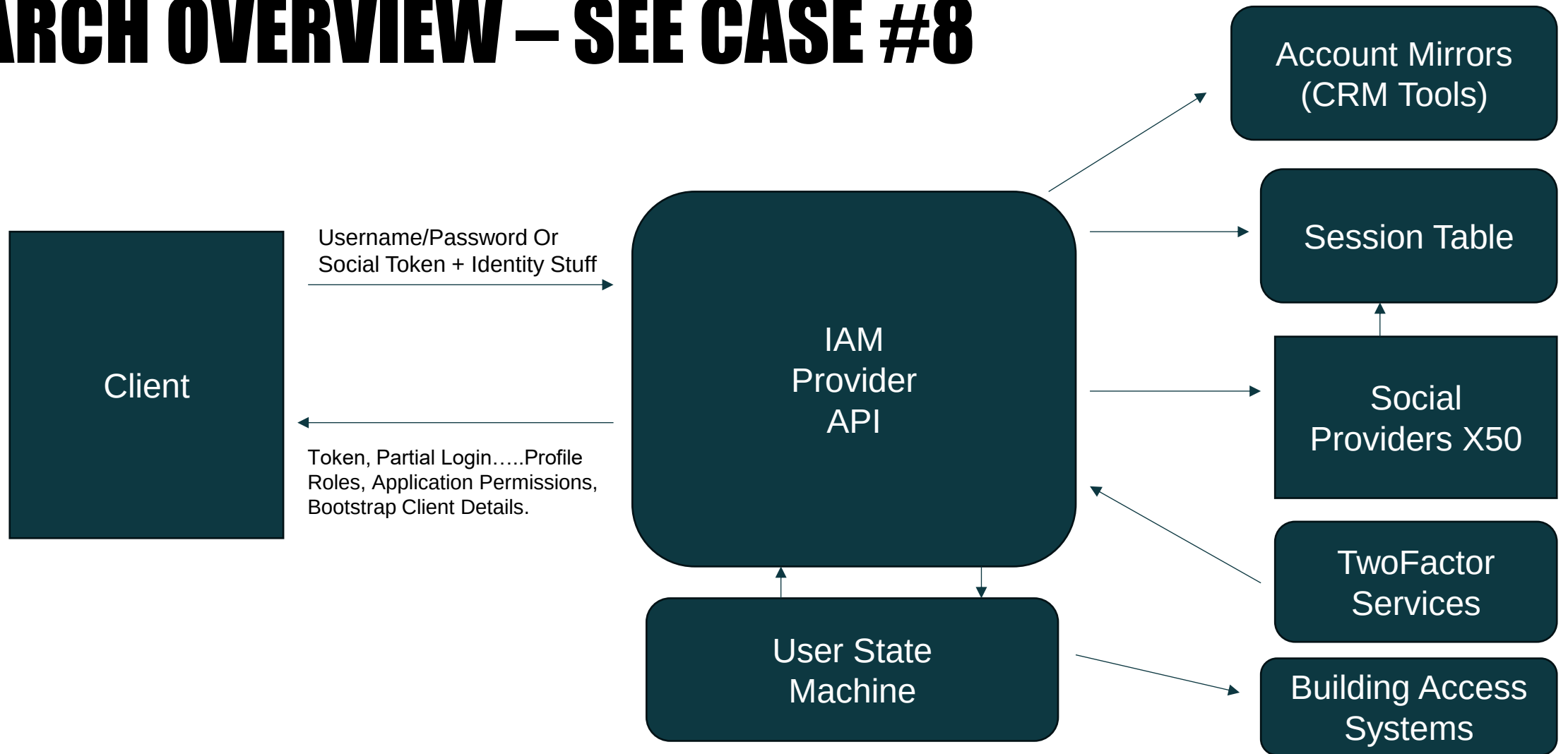


HEADLINE

- API SSO
- SOCIAL MEDIA EXTENSIONS
- COMBINED OPERATIONS FOR TWO FACTOR AUTHENTICATION



ARCH OVERVIEW – SEE CASE #8



TO DELIVER SSO: MINIMUM

STEP1 -> You have to validate a username and password against an API, SSO Provider or Local database using a CRM tool or Enterprise Domain Manager. And Generate a login token which has the time of access at a minimum. It needs to be complex and cant be guessed.

STEP2 -> You have to create a session table with the list of logged in users. If this is an API this is a server side call. If this is a local DB there may be a proprietary database insert. The Session Table has to store the token generated by Step1.

STEP3 -> You have to return the token to the client which is how it validates its roles and permissions, and age of login.

OPTIONS: CRM Tools(Joomla, Wordpress, Drupal), Social(G, FB, Yahoo, IG, MSFT), Microsoft Domain Controller, Microfocus/Novell eDirectory > 90% market share collectively. Proprietary API calls < 10%.



SSO ARCHITECTURES USING COMPLEX MODELS

- Allowing logins in multiple forms is common on the Internet.
- Example Spotify Music Service, NYT, WashingtonPost, etc... all support complex login processes which have unique characteristics.
- For Example... you have your own API/SSO process you have invested for your enterprise Acme.com.... But no one is using your website as they don't want to maintain an Acme.com login.
- Acme has three options: 1) Partner with a Big SSO provider which can provide direct feeds to them with real data for a price. 2) Accept a validated social login token 3) Use Microsoft EntraID which could extend Acme domain controllers to the Internet as a cloud tenant 4) There is a company called one-all which does a complex smash up which is two level model. 5) Build your own API. 6) Use a CRM login. 7) Use PAM based login with Unix LDAP extensions.
- Acme could do all five... which is a complicated process.... Which we are trying to accomplish....



CASE1 – PARTNER WITH A BIG COMPANY

- Google Business does offer a Yourdomain.com service. It requires they control your DNS or have a secondary DNS write capability to synch to your primary controller.
- Acme.com becomes a google shared domain. You add users on google, and they work for your entire enterprise.
- Option2: You are a big Facebook Customer.... And they sign a custom deal for IAM where they let you do your account management for your enterprise with them. Then you are riding their SSO system for your enterprise... also a good deal.
- They all can do this if they want to... but Google is only company which has this productized. This is very cool as your personal devices can use GMAIL to the company and personal mail at same time.
- Apple Accounts also have this capability. New Apple Servers can use AppleID global ID systems.



CASE2 PT1 -> ACCEPT A VALIDATE SOCIAL TOKEN.

- In this model, you login to a Google, Facebook, Other Third party token service as all Social companys usually offer an identity service.
- In this model a Facebook user logs into his normal account and has a login token. When he clicks on your login, Facebook validates the additional service, and returns a secondary token to you the service provider which is validated.
 - “Facebook is telling you this user is valid on their system(which doesn’t mean they are a real person), and will return a working email, and phone number if their customer lists it.
 - You as an App provider now have a validate user from Facebook, and basics of the login....BUT HERE IS THE PROBLEM....
 - #1 -> The User may not exist on your system yet.
 - #2 -> The User may exist on your system already before they used social media.
 - #3 -> The User may have used a social media login before.



CASE2 - SOCIAL PT2 – WHAT TO DO NOW?

- You've Got a valid token you have to decide what to do with it....
 - #1 – You have to check the email, or phone number returned from the Social company. If it doesn't exist, you need to build a new account. The account type is ThirdParty Social... and you don't have their password.... So you have to restrict logins to only this type of access. If you build a new account you need to then add a session for the first access, OR make them login again(As most sites do).
 - #2 – Second or more uses...After the second use, you have to continue to put a foreign session cookie/token in your session table. That means your session process has to accept and have multiple fields for the token. Your client/app has to use this token to check its own status.
- Invalid Tokens
 - You don't have a good login from Google, Facebook, etc... which could mean two things... the User is bad, or your controller is broken... this is a complex process.
- When things work right....your validated social token, matches an existing email, and is given permissions associated with that account. That means that usually a Social Login is always a GUEST user. They cannot be an admin.
- If a Social User Needs to be an Admin... you have to have an exception process to understand why they want to do that and if you are comfortable with it.... Usually not. Admins usually have to be a local account, and have special 2 factor authentication. Why? A FB/Google Account only needs access to someones phone for a few seconds, or if 2factor is off you wont know.
- EXTRAS -> You can still request 2factor post social login to validate that you have all the right information... and this might help clean up your own database information. You could for example require 2factor SMS to use the service from Facebook, google, etc.



CASE 3 -> MICROSOFT ENTRA ID

- Microsoft Entra IDs do create tokens and are just like any other social provider...BUT... usually you own the domain controller, and have full information in Azure... it's a pretty good solution.
- This process is the same as Case2.



CASE4: COMPLEX SSO FROM INTERNET PROVIDER

- There are several Internet IAM providers which do this complex process for you... its very complicated with lots of sub tree problems which we have solved over the years....
- Examples OpenAPI.com (which has its own clients and CRM plugins to Drupal, WP, Joomla)
- Examples Oneall.com
 - We like Oneall.com they provide local javascript where a user is authenticated against their network, and then they manage session tables against the Social companies. They also provide user registration.
 - Their service is brilliant and can show you how people login from all over the world.... Heat maps, consolidated profiles... and per application reporting... for a reasonable price.
 - We have been customers for 10+ years. MSFT signed a contract while building EntraID.



CASE5: BUILD YOUR OWN API

- This is a complex process in itself...
- You tie a REST API to a database with a user table.
- You build a Session table.
- When a user logs in... you create a session on the backoffice.
- You return your own token, and you have TO TELL THE APP what to do with it...or let them decide.
- You have to make the APP reregister the token every so often(4 hours or so or log them out). You have to deny access to tokens to access your API which are not valid.



CASE6: USE A CRM TOOL

- Joomla, Drupal, and Wordpress all set cookies in a common format... you can use their logins, and accept their cookies...
- Since these CRM tools are opensource you can customize their cookies, and session management.
- Joomla is our choice, and has a 2nd level validation to OneALL. A Joomla login therefore can be seamlessly integrated in with 50+ social sites using a Joomla Cookie (Our Very Good Pick).
- Wordpress runs 80% of sites on the Internet... They also have social media plugins which tie to your site... (We use this too)...



CASE7: OLD TRUSTY...THE UNIX MODEL

- Complex unix systems have an encrypted password file which is a flat file. Its salted... and well 10's of billions of people have tried to break it an failed...
- Unix Pam was adopted by Linux.....
- AND well they synch to things like OpenLDAP.... If you create a PAM user, they synch to NIS+ and other network services.
- PAM logins can be extended to CRM tools like Joomla/Drupal/WP CRM via plugins... making Case6 kinda cool...
- Or just use Unix Logins.....
- NOW Novell... is the US Government standard... and they use PAM to eDirectory synching which also supports APP registration and permissions. Thus eDirectory tokens can validate to application permissions in complex ways.



CASE 8 -> JUNK IT ALL... AND BUILT YOUR OWN ONE ALL?

- Well with an API... you can validate a login and generate a token... and extend that token to social media OATH providers as a second stage process.
- In this case your apps communicate to the API only... and the API handles everything else automagically....
- We are going to try to build that in this class as a unique architecture.
- Since Joomla cookies are standardized, we can even create a Joomla account on the back-end, that even has a salted password with it by API. Then everything works...



THE TRUTH... SUPPORTING ALL 8 PROCESSES....

- Has literally taken 14 years of education and training...
- And STILL that doesn't cover Enterprise SSO which is tied with Access Management
 - For Example old employers tie Domain logins to badge access readers in complex ways.
 - If you go to a US Government Contractor of any size... they all have proprietary SSO which you have to deal with.... And that's STILL a per site Engineering Exercise....
 - And for Verizon/ATT and the other baby bells they have to deal with Government SSO, Military SSO, and more...
 - So Digital Identity is a whole lifetime sport which is never going away and gets more complicated every year.



TO PUT THIS IN PERSPECTIVE....

- This is a 10 year project with 10 engineers in size and scope...
- It requires significant research to all 50+ social engines and their IAM process... so even if you know your own... each foreign domain is unique and needs an adapter layer....
- AI makes this achievable mainly because the AI engines can read all the standardized docs and code samples, and give them back to you summarized.....
- AI reduces this cost by 50FTEs approximately. It lowers the cost to fulfillment.
- It's a 798 Project in itself. (3CH->12CHs). It's a massive PHD level project.



THANKS!

Name

Title

Email

Social



UNIVERSITY OF
South Carolina